FIELD REPORT / ENDPOINT GOVERNANCE

Microsoft Intune: A Senior Engineer's Five-Question Design Review

An expanded engineering case study with scoped roles, PowerShell checks, approval gates and measurable outcomes

AUTHOR / MARC LAVOIE All organizations, counts, personnel and test results in this scenario are fictional. Microsoft product behaviors and command patterns are supported by the primary references in the references at the end.

The engineering decision

Northstar Services operates 2,400 managed endpoints. A proposed Windows compliance baseline will feed a Conditional Access rule for Microsoft 365. A prior broadly assigned change interrupted remote staff, so Marc, acting as lead endpoint security engineer, requires an explicit target list, a user recovery path, telemetry, separate approval, and a stop condition before expansion.

Endpoint class	Count	Decision for this change
Corporate Windows endpoints	1,800	In scope for a four-stage compliance and access rollout.
Personally owned iOS/Android	350	Out of this Windows change; plan a separate app protection path.
Dedicated kiosks	150	Out of this user-based policy; assess kiosk sign-ins separately.
Shared Windows stations	100	Out of pilot until account and ownership behavior is tested.

Proposed rings: 20 pilot devices, then 80, then 250, then 1,450. Expanding each ring is a new decision backed by device reports, sign-in evidence, and change approval. All thresholds in this paper are scenario choices rather than Microsoft limits.

GOVERNING PRINCIPLE A successfully saved policy is not yet an operational success. Prove the eligible population, device state, access decision and administrative boundary before broadening its assignment.

01 / WHAT ARE WE MANAGING?

Define the population before touching policy

Use **SG-INT-WIN-PILOT**, a static security group containing 20 named users, each paired with one approved corporate Windows endpoint. Assign the Windows compliance policy to that group with an **Include** managed-device assignment filter **(device.deviceOwnership -eq "Corporate")**. Before saving, preview matching devices and compare the resulting list against the approved roster. Assignment filters narrow Intune assignments; they do not target Entra Conditional Access policies [2, 6].

Boundary	Example control	Failure to catch
Users	20 named users; independently reviewed group membership.	Nested or stray members extend scope.
Devices	Windows compliance + corporate ownership filter.	Bad ownership record or shared PC matches.
Resource	Pilot Conditional Access targets selected Microsoft 365 resources.	All-resources targeting blocks unrelated workflows.
Admins	Policy editor, approver and CA admin are separate people/groups.	One account can edit and promote unchecked.

02 / WHAT DOES HEALTHY MEAN?

Define pass/fail and the exception owner

This example measures BitLocker encryption, Secure Boot and a tested minimum Windows version. A configuration profile can configure settings; a compliance policy evaluates the resulting state. Validate hardware support, BitLocker recovery arrangements and conflicting policies before deployment. Do not substitute an automatic wipe for a remediation procedure [3, 4].

Signal	Acceptance threshold in pilot	Owner
BitLocker	20/20 compliant; test recovery access on two lab devices.	Endpoint engineering.
Secure Boot	20/20 eligible devices pass; investigate unsupported hardware.	Endpoint engineering.
OS and freshness	20/20 meet approved version and checked in within 24 hours.	Workplace IT.

Remediation interval: the default Mark device noncompliant action takes effect immediately. For this illustrative rollout, change its schedule to two days and send a noncompliance email after reviewing the notice. That changes when Intune marks a failed device noncompliant; it does not create a separate Conditional Access timer [4].

03 / HOW DOES FAILURE AFFECT ACCESS?

Connect compliance to a scoped sign-in decision

Create a **separate Entra Conditional Access policy** for the pilot users. Select the Microsoft 365 resources in the test, require a compliant device, exclude documented emergency access accounts, and start in **Report-only**. Ensure at least one pilot device is compliant first. Test a passing Windows device, a deliberately noncompliant test device and a controlled emergency sign-in; examine the policy result on each sign-in [5, 7].

Test sign-in	Expected decision	Evidence
Compliant corporate Windows	Microsoft 365 succeeds when policy is On.	Device identity and applied CA result.
Noncompliant test device	Report-only predicts failure; enabled policy prevents access until remediated.	Failed grant control and repair route.
Not evaluated / newly enrolled	Do not enforce until state and enrollment path are understood.	Policy assignment and device check-in.
Emergency account	Excluded from this blocking policy.	Controlled test and alerting.
BYOD phone or kiosk account	Handled by a separate plan, especially if the user is also in pilot.	Cross-device user membership check.

What the affected employee sees

A remote pilot laptop stops satisfying Secure Boot. The service desk points the user to the relevant remediation steps. If the compliance schedule permits a two-day grace, Intune does not mark it noncompliant during that grace period. After the grace period, a failed device status can make an enforced compliant-device grant fail at a targeted sign-in. Existing sessions and refresh behavior can vary, so engineers validate with real clients and sign-in logs rather than assuming an instant cutoff [4, 5, 7].

> **TWO SIMILAR-SOUNDING FILTERS** The Intune managed-device ownership filter uses "Corporate". A separate Entra Conditional Access device filter uses "Company" for its ownership value. Neither is interchangeable with the other, and this scenario does not need a CA device filter [6, 8, 14].

Promotion gate

Only turn the new CA policy On when all 20 pilot devices have a fresh evaluated status, expected pass/fail sign-ins appear in logs, emergency access has been tested, the help desk has the repair steps, and the change approver signs the decision. Report-only does not block the user [5, 7].

04 / HOW DO WE KNOW IT WORKED?

Use device, sign-in and change evidence

A deployment-success badge alone cannot prove that users still reach Microsoft 365. Combine Intune's per-policy and per-setting compliance reports, Entra sign-in details with applied Conditional Access outcomes, and RBAC/audit/approval records for the change [3, 7, 9].

Evidence stream	Where to look	What to record
Compliance	Intune > Devices > Compliance > policy > Monitor and Per-setting status.	20 devices, settings, errors, not evaluated.
Device freshness	Managed device complianceState and lastSyncDateTime.	Match 20-device roster; no stale device.
Sign-in result	Entra > Monitoring & health > Sign-in logs > Conditional Access.	Expected policy ID, grant and user experience.
Authority	Intune > Tenant administration > Roles > Monitor; audit and MAA requests.	Requester, separate approver and change ID.

Pre-agreed acceptance record: fictional pilot

Gate	Required before ring 2	Observed at 10:05 UTC
Target accuracy	20 named endpoints and 0 unintended devices.	20 match: pass.
Fresh data	20/20 pilot devices checked in within 24 hours.	19/20: one device stale; HOLD.
Access behavior	Passing and failing test sign-ins match expectations.	Both expected report-only results observed.
Support load	No more than two unexplained tickets in 24 hours.	One stale-device ticket; investigate.

ACTUAL DECISION The 80-device wave is held. A correct report-only sign-in on two test identities cannot replace fresh device evidence for the twentieth pilot endpoint. Investigate policy assignment, management state and last check-in before retesting.

Attribution: a noncompliant device and a failed sign-in do not alone prove this new policy caused the user's problem. Inspect applied Conditional Access policies and the precise grant failure, and compare other policies and the last device sync [7, 9].

05 / HOW DO WE LIMIT THE BLAST RADIUS?

One change, several independent boundaries

Assignment groups and filters decide which enrolled devices receive an Intune policy. An **Intune RBAC role** permits actions; its **scope groups** constrain managed users/devices, and **scope tags** govern visibility of tagged Intune objects. **Conditional Access** determines resource access at sign-in. **Multi Admin Approval (MAA)** holds supported high-impact Intune changes until another administrator approves [1, 2, 10].

> **PERMISSION-MERGE CAVEAT** Under Intune's documented default behavior, permissions across assignments with different scope tags can merge. Check the Admin permissions and Permissions Assessment reports. The Scoped permissions setting was documented as an opt-in, irreversible public preview; do not turn it on merely to fix this example [2].

Control	Concrete placement	Avoided impact
Targeting	20-user group + corporate Windows filter; distinct later rings.	Bad configuration on all 1,800 laptops.
RBAC	Policy and Profile Manager for policy editor; selected scope groups and NS-WIN tag.	Editor managing unintended users/objects.
Conditional Access	Pilot users, tested Microsoft 365 resources and emergency exclusions.	Access failures outside test population.
MAA	Compliance, settings catalog, RBAC and destructive device actions.	A lone account applies a protected change.

A workable access assignment

Editor: SG-ADM-INT-POLICY is the admin group on a Policy and Profile Manager role assignment. Scope groups are approved corporate Windows users/devices; scope tag NS-WIN appears on the applicable policies and test devices. Review the actual permission matrix for the built-in role [1, 2].

Approver: SG-ADM-INT-APPROVER is a non-mail-enabled security group with direct members. Add this group directly to an Intune role assignment and grant resource-specific Read permissions so its members can approve protected changes. The requester cannot approve their own request [10].

Observer: use a custom Read/report role for support analysts. The built-in Help Desk Operator can perform high-impact remote actions, making it a poor default for a purely observational job [1].

OPERATOR NOTEBOOK / POWERSHELL

Build the pilot group, then inspect real results

The examples below assume Microsoft Graph PowerShell, approved delegated privileges and a fictional contoso.example identity. The first sample **creates** one group and adds one resolved person. It was not run against a tenant while preparing this report [11, 12].

```
Connect-MgGraph -Scopes 'Group.ReadWrite.All','User.Read.All'
Get-MgContext | Select-Object TenantId,Account,Scopes
$pilotGroupParams = @{
  DisplayName = 'SG-INT-WIN-PILOT'
  MailEnabled = $false
  MailNickname = 'sgintwinpilot'
  SecurityEnabled = $true
}
$pilot = New-MgGroup @pilotGroupParams
$person = Get-MgUser -UserId 'pilot.user@contoso.example'
if (-not $person.Id) { throw 'User not resolved: stop.' }
$ref = @{
  '@odata.id' = "https://graph.microsoft.com/v1.0/directoryObjects/$($person.Id)"
}
New-MgGroupMemberByRef -GroupId $pilot.Id -BodyParameter $ref
Get-MgGroupMember -GroupId $pilot.Id -All | Select-Object Id
```

Admin-center configuration: In Intune, create a Windows managed-device assignment filter using **(device.deviceOwnership -eq "Corporate")**; attach it in Include mode to the pilot compliance assignment. Under Tenant administration > Roles > All roles, assign the selected role with its admin group, scope groups and NS-WIN scope tag. Under Multi Admin Approval, protect the supported policy type and configure the separate approver group. In Entra, build the distinct Conditional Access policy in Report-only [1, 2, 5, 6, 10].

Read-only evidence queries

```
$scopes = @(
 'DeviceManagementManagedDevices.Read.All'
 'AuditLog.Read.All'
 'Policy.Read.ConditionalAccess'
 'Directory.Read.All'
)
Connect-MgGraph -Scopes $scopes
$win = Get-MgDeviceManagementManagedDevice -All |
  Where-Object OperatingSystem -eq 'Windows'
$win | Select-Object DeviceName,ComplianceState,LastSyncDateTime |
  Sort-Object DeviceName
$ca = Get-MgIdentityConditionalAccessPolicy |
  Where-Object DisplayName -eq 'CA-INT-WIN-PILOT-M365'
$ca | Select-Object Id,DisplayName,State
$since = (Get-Date).ToUniversalTime().AddDays(-1).ToString('s')+'Z'
$signins = Get-MgAuditLogSignIn -Filter "createdDateTime ge $since" -Top 100
$signins | Select-Object CreatedDateTime,UserPrincipalName,
  AppDisplayName,ConditionalAccessStatus
```

Limits: The managed-device query is tenant-wide until you compare it to the approved roster. The sign-in command samples 100 results, so paginate and filter in production. Individual sign-ins show applied Conditional Access policies only when the signed-in account and token have the needed read access [7, 9, 13].

CHANGE CONTROL / ROLLOUT AND RECOVERY

Promotion is an evidence decision

Ring	Population	Minimum gate to continue
0 - prepare	No devices	Baseline and repair steps approved; administrative permissions reviewed.
1 - pilot	20 Windows	20/20 fresh and correctly targeted; pass/fail sign-ins; emergency test.
2 - first wave	+80 Windows	24-hour observation and no unexplained access denial.
3 - measured	+250 Windows	Same checks by location and hardware model; separate approval.
4 - remainder	+1,450 Windows	Approved window, sign-in monitoring, assigned rollback owner.

Failure injection: one stale laptop

At 10:05 UTC, 19 of 20 pilot devices report a fresh compliance result. The last laptop is offline and still Not evaluated. Marc leaves Conditional Access in Report-only and holds the 80-user wave. The endpoint engineer checks ownership, enrollment, assignment and sync. The Conditional Access admin checks the user's sign-in. The service desk tests repair instructions. Once the device reports a fresh evaluated state, the team repeats the roster comparison and sign-in tests; a different administrator reviews the evidence before ring 2 proceeds.

Unexpected observation	Immediate control	Proof required to restart
Wrong users/devices targeted	Stop expansion; fix group, assignment or filter.	New target export, policy status and approval.
Unanticipated access block	CA admin returns only the new pilot CA policy to Report-only.	Applied sign-in policies and passing retest.
Surge in noncompliance	Policy editor stops expansion; restores the documented earlier assignment/settings if justified.	Fresh device and per-setting reports.

Example containment command: CA administrator only

Following the incident gate, the authorized Conditional Access administrator can return this uniquely identified pilot policy to Report-only. Verify the policy ID and reason in the change record; this operation does not change the Intune compliance policy [5, 15].

```
Connect-MgGraph -Scopes 'Policy.Read.All','Policy.ReadWrite.ConditionalAccess'
$match = @(Get-MgIdentityConditionalAccessPolicy |
  Where-Object DisplayName -eq 'CA-INT-WIN-PILOT-M365')
if ($match.Count -ne 1) { throw 'Policy not uniquely identified.' }
$rollbackParams = @{
  ConditionalAccessPolicyId = $match[0].Id
  BodyParameter = @{ state = 'enabledForReportingButNotEnforced' }
}
Update-MgIdentityConditionalAccessPolicy @rollbackParams
```

Wipe or retire is not a rollback for a mistaken compliance or access assignment. Returning a Conditional Access policy to Report-only is a distinct Entra administrative action; the Intune policy editor's RBAC role does not itself grant it [1, 5, 10].

METHOD / RESEARCH QUESTION

A defensible engineering decision

Question. How can a senior engineer improve Windows compliance without creating an organization-wide access incident? This hypothetical design exercise separates policy targeting, sign-in decisions, delegated authority, and evidence. Product behavior and syntax are grounded in Microsoft's primary documentation [1-26]; the organization's numbers, actors, results and thresholds are illustrative.

Review question	Proof before promotion	Owner
Population	Named roster, ownership, platform and exclusion check.	Endpoint lead
Health	Encryption, Secure Boot, OS level and fresh cloud state.	Engineering
Access	Passing/failing sign-ins and emergency path.	Identity
Outcome	Compliance, sign-in and change records agree.	SOC
Authority	Allowed and forbidden actions tested for every admin.	Change owner

Falsifiable rollout hypothesis

Promote only if the target list matches the approved population, the device states are fresh, sign-ins behave as designed, and the people making the change cannot exceed their assigned scope. A stale device, unexpected CA match or privileged negative test that succeeds disproves the hypothesis and holds the next wave. A successful portal Save is only the start of validation.

> **EVIDENCE RULE** A missing result is not a passing result. The fictional pilot has 19/20 current reports at 10:05 UTC, so the next wave remains on hold despite two correct report-only sign-ins.

The endpoint engineer signs the device and target inventory; the identity engineer signs the applied CA outcomes; security operations checks authority and tickets; the separate approver signs each larger ring. This division of work is a proposed procedure, not a Microsoft product default.

RBAC / ASSIGN REAL JOBS

Six roles with measurable limits

Names of built-in roles can hide powerful actions. The following job design uses custom Intune roles where a built-in role would grant more authority than the task needs; review Microsoft's current permissions table and test the effective result [1, 16, 17].

Job / assignment	Permitted work	Deliberate boundary
Compliance editor / custom	Compliance Read, Create, Update, Assign and View reports.	Pilot scope group; NS-WIN-PILOT tag; no Delete.
Profile engineer / custom	Device configurations Read, Create, Update and Assign.	Separate group, approval and test target.
Security observer / custom	Compliance Read/View reports and Managed devices Read.	No Update, Wipe, Retire or key access.
MAA approver / custom	Resource-specific compliance Read; review protected request.	Distinct direct group member; no self-approval.
Delegation owner / Intune Role Administrator	Create, assign, review Intune roles.	Temporary access and independent RBAC approval.
CA operator / Entra CA Administrator	Pilot CA grant, report-only state and rollback.	No Intune compliance edit from CA role.

Privilege checks: Policy and Profile Manager can create, delete and assign compliance and configuration policies. Endpoint Security Manager includes compliance permissions and some remote tasks. Help Desk Operator includes Wipe and Retire. Read Only Operator includes Get FileVault key. Verify every action in the permission matrix before assigning any built-in role [16].

> **SEPARATE CONTROL PLANE** The Entra Intune Administrator role grants broad Intune access without Intune RBAC scope-tag limits; Entra Conditional Access Administrator manages the separate sign-in policy. Intune Role Administrator manages Intune delegation [1, 2, 16].

RBAC / ASSIGNMENT RECIPE

Set role, people, scope and visibility

For each Intune role, go to Tenant administration > Roles > All roles > role > Assignments > Assign. Supply an administrator group, scope groups containing the users/devices the admin may manage, and scope tags on the objects the admin may see. Validate the resulting permissions with an administrator test account [1, 2, 18].

Field	Compliance editor	Security observer
Role rights	Compliance Read/Create/Update/Assign/View reports.	Compliance Read/View reports; devices Read.
Admin Groups	SG-ADM-COMPLIANCE-EDIT, direct members.	SG-ADM-SEC-REVIEW, direct members.
Scope Groups	SG-INT-WIN-PILOT only.	SG-INT-WIN-PILOT only.
Scope Tags	NS-WIN-PILOT on role and eligible objects.	NS-WIN-PILOT on eligible objects.
Forbidden test	Assign policy to all 2,400 devices.	Change policy; wipe; reveal key.

Three superficially similar boundaries

Policy assignment targets recipients; an Intune device filter can narrow the matched devices. **RBAC scope groups** bound which users and devices an administrator may manage. **Scope tags** govern visibility of tagged Intune objects; they do not deploy policy. Some object types have no scope tag. Only target groups listed in the admin's scope groups can be assigned through that role [1, 2, 6].

Access-review test: sign in as each delegated identity, open Admin permissions and Roles by permission, compare actual group IDs and tags with the signed assignment sheet, perform one allowed action in a disposable test ring, then attempt one forbidden action. Keep the result in the change record [1, 2].

> **APPROVER SETUP** The separate MAA security group must itself be directly assigned as an Intune role member group; approvers must be direct members and have the resource-specific Read right. Another human approves the request [10].

RBAC / FAILURE INJECTION

How a second role can widen the first

Admin Alex has assignment A with compliance-policy Read on NS-NORTH and assignment B with compliance-policy Update on NS-SOUTH. Under Microsoft's documented default behavior, permissions in the same category can merge across role assignments with different scope tags: Alex might update North. The boundary must be tested, not inferred from tag names [2].

Assignment	Intended	Surprising effective result
A / NS-NORTH	Read North compliance policies.	Update from B can extend to North.
B / NS-SOUTH	Update South compliance policies.	South also remains writable.
Negative test	Attempt a harmless North test edit.	If it succeeds, STOP promotion.

Repair without widening access

Review Admin permissions, Roles by permission and the Permissions Assessment report. Identify the group memberships that produced both assignments; remove overlapping same-category authority or give the editing duty to a separate identity. Repeat the prohibited-action test and inspect the full set of tags and scope groups. Log the before-and-after effective permissions [1, 2].

Microsoft describes an opt-in Scoped permissions public preview introduced in March 2026. Its different behavior isolates permissions within a role assignment context, but Microsoft documents the opt-in as irreversible. Evaluate its Permissions Assessment report and migration impact before enabling; this scenario assumes the default behavior [2].

> **ESCALATION TRIGGER** If a support account can Update, Wipe, Retire or read a recovery key beyond its job, freeze the wave and repair access. A fresh tag applied to a policy is insufficient evidence that the privilege leak was fixed.

POWERSHELL / TARGET PREFLIGHT

Fail closed on an unexpected pilot roster

This read-only guard compares approved user object IDs from the change ticket with current direct group members. Fill the full approved roster first: the abbreviated two-ID sample below intentionally fails the twenty-person check. Compare the Intune filter preview separately [6, 19].

```
Connect-MgGraph -Scopes 'GroupMember.Read.All'
$pilotId = '<approved-pilot-group-object-id>'
$approvedIds = @('<approved-id-01>','<approved-id-02>')
# Replace with all 20 approved IDs from the signed ticket.
$members = @(Get-MgGroupMember -GroupId $pilotId -All)
$actual = @($members | ForEach-Object Id | Sort-Object -Unique)
$wanted = @($approvedIds | Sort-Object -Unique)
if ($members.Count -ne 20) { throw 'Pilot count differs: HOLD.' }
if (@(Compare-Object $wanted $actual).Count -ne 0) {
  throw 'Pilot membership differs: HOLD.'
}
'Approved direct membership matched.'
```

Verify the compliance policy target

```
Connect-MgGraph -Scopes 'DeviceManagementConfiguration.Read.All'
$policyId = '<approved-pilot-compliance-policy-id>'
$path = "https://graph.microsoft.com/v1.0/deviceManagement/" +
        "deviceCompliancePolicies/$policyId/assignments"
$items = (Invoke-MgGraphRequest -Method GET -Uri $path).value
$items | ForEach-Object {
  [pscustomobject]@{
    TargetType = $_.target.'@odata.type'
    GroupId = $_.target.groupId
    FilterId = $_.target.deviceAndAppManagementAssignmentFilterId
  }
} | Format-Table
```

Inspect the full target JSON if fields are absent or the target subtype differs. Stop if the group ID is not the signed pilot group or if an All devices target appears. Verify filter mode and filter preview in the Intune admin center; do not assume a group check proves device ownership [6, 20].

POWERSHELL / PERMISSION INVENTORY

Inspect every admin group and scope group

This Microsoft Graph v1.0 reader follows pagination and inventories Intune role definitions and assignments. It does not establish effective permissions by itself; compare with Intune's Admin permissions and the Permissions Assessment report, including all scope tags [1, 2, 21, 22].

```
Connect-MgGraph -Scopes 'DeviceManagementRBAC.Read.All'
function Get-GraphPages([string]$uri) {
  while ($uri) {
    $r = Invoke-MgGraphRequest -Method GET -Uri $uri
    foreach ($item in $r.value) { $item }
    $uri = $r.'@odata.nextLink'
  }
}
$base = 'https://graph.microsoft.com/v1.0/deviceManagement'
$defs = @(Get-GraphPages "$base/roleDefinitions")
$roles = @(Get-GraphPages "$base/roleAssignments")
$defs | Select-Object id,displayName,isBuiltIn | Format-Table
$roles | ForEach-Object {
  [pscustomobject]@{
    Name = $_.displayName
    AdminGroups = ($_.members -join ',')
    ScopeGroups = ($_.resourceScopes -join ',')
  }
} | Format-Table -Wrap
```

Interpretation: Resolve the returned group IDs against approved admin and scope groups. Examine the role's full permission actions and all other roles held by each admin. The v1.0 list does not replace an effective-authority test and a review of tagged object visibility [1, 2, 21, 22].

> **NEGATIVE TEST** As the compliance editor, attempt to target an out-of-scope group; as the observer, attempt Update and Wipe; as an NS-SOUTH editor, attempt a harmless NS-NORTH test edit. Any surprising success holds the next ring.

POWERSHELL / ONE LAPTOP, THREE EVIDENCE SOURCES

Diagnose a failed control before access changes

On an approved pilot laptop, check disk protection, firmware and device identity. Then compare Intune's evaluated compliance and the exact applied Conditional Access policy. Local healthy status is not proof of a fresh cloud compliance result [3, 7, 23-25].

```
# Observational Windows PowerShell on the affected laptop
$disk = Get-BitLockerVolume -MountPoint $env:SystemDrive
$disk | Select-Object MountPoint,VolumeStatus,ProtectionStatus
try { Confirm-SecureBootUEFI }
catch { Write-Warning ('Secure Boot: ' + $_.Exception.Message) }
(Get-ComputerInfo).WindowsVersion
Get-Date -Format o
# Join/device identity and token clues; redact before sharing
& dsregcmd.exe /status
```

Observation	Next check	Decision
Encrypted, Protection Off	Suspend state and recovery readiness.	Hold until protected.
Secure Boot false or error	UEFI mode and model eligibility.	Hold model wave.
Local pass, Intune stale	Matching device ID and lastSyncDateTime.	Hold until evaluated.
Compliant, sign-in denied	Applied CA rule, grant, device claim.	Correct the actual cause.

Cloud correlation: use the earlier managed-device and sign-in queries. Match device ID, time, user and applied CA policy ID. The sign-in command shown earlier samples 100 items: filter to a short approved window and paginate when collecting evidence [7, 9, 13].

> **PRIVACY AND AUTHORITY** Diagnostic output can include device/user identifiers. Store the minimum in a restricted change record; no command here extracts or rotates BitLocker recovery keys. A CA operator controls the sign-in grant, while the endpoint engineer repairs the device.

CHANGE ASSURANCE / INDEPENDENT APPROVAL

Prove a reviewer can stop the change

Configure Intune Multi Admin Approval (MAA) on supported compliance, configuration, RBAC and destructive device actions where available. The reviewer must hold the resource-specific Read right, belong directly to the assigned security group, and be a different account. When MAA is active for a protected workload, application-authenticated Graph writes also require its workflow [10, 26].

Gate	Ticket artifact	Accountable actor
Submit	Change ID, exact policy ID, old/new target, justification.	Editor
Review	Roster, filter preview, negative role test, impact estimate.	Approver
Complete	Approved MAA request and resulting audit event.	Original editor
Observe	Per-setting, sign-in and help-desk evidence by wave.	SOC / identity
Contain	Specific CA policy returned to Report-only if access fails.	CA operator

Tabletop: the North/South RBAC boundary fails

At 09:40, an NS-SOUTH editor successfully updates a harmless NS-NORTH test policy because a second assignment supplies Update in the same compliance category. The change owner holds the +80 wave. The role administrator removes the overlapping assignment, checks all remaining admin memberships, and repeats both allowed and forbidden tests. The identity engineer confirms sign-in outcomes did not drift. The independent approver signs a new record before expansion [1, 2, 10].

> **SENIOR DECISION** Do not solve the issue by adding Intune Administrator, widening to All devices or deleting the policy. Repair the exact authorization path, retest and document who approved the new effective permission.

DESIGN REVIEW / EXECUTIVE SCORECARD

The competency demonstrated by the case

Engineering competency	Observable result in this design
Architecture	Five questions connect fleet, health, access, telemetry and delegation.
Access controls	Differentiate policy group, assignment filter, RBAC scope and tag, CA.
Change discipline	20 > 80 > 250 > 1,450 rings, each with an explicit stop gate.
Automation	Guarded group check, policy-target query, RBAC inventory, local triage.
Incident response	Device and sign-in correlation plus a precise CA rollback action.
Governance	Role negative tests, permission merge analysis, independent MAA.

Fictional decision memo / 10:05 UTC

Recommendation: HOLD ring 2. Nineteen of the twenty pilot endpoints have a current report; one remains Not evaluated. The two report-only sign-ins matched the expected outcomes, but the required device freshness gate is unmet. Endpoint engineering owns the stale identity/sync investigation. The CA operator keeps the new CA policy in Report-only. A separate reviewer compares the corrected roster, per-setting results and sign-ins before approving the next eighty devices. This is an illustrative engineering exercise, not a production incident report.

> **TRANSFERABLE PRACTICE** A senior engineer joins authority to change, the exact affected population, and measured user impact in one reviewable decision. A failed gate has a named owner and stops expansion.

PRIMARY MICROSOFT DOCUMENTATION

References / architecture and access

Documentation reviewed 22 October 2026. Figures, names and measured outcomes are hypothetical.

[1] Microsoft. Intune RBAC overview and assignment boundaries.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/overview

[2] Microsoft. Scope tags and permissions across assignments.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/scope-tags

[3] Microsoft. Monitor compliance policy results.
https://learn.microsoft.com/en-us/intune/device-security/compliance/monitor-policy

[4] Microsoft. Configure noncompliance actions.
https://learn.microsoft.com/en-us/intune/device-security/compliance/configure-noncompliance-actions

[5] Microsoft. Require a compliant device with Conditional Access.
https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-all-users-device-compliance

[6] Microsoft. Intune assignment filters.
https://learn.microsoft.com/en-us/intune/fundamentals/filters/overview

[7] Microsoft. Applied Conditional Access policies in sign-in logs.
https://learn.microsoft.com/en-us/entra/identity/monitoring-health/how-to-view-applied-conditional-access-policies

[8] Microsoft. Intune device filter property syntax.
https://learn.microsoft.com/en-us/intune/fundamentals/filters/ref-device-properties?tabs=managed-device

[9] Microsoft. List sign-ins with Microsoft Graph.
https://learn.microsoft.com/en-us/graph/api/signin-list?view=graph-rest-1.0

[10] Microsoft. Multi Admin Approval in Intune.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/multi-admin-approval

[11] Microsoft. New-MgGroup cmdlet.
https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.groups/new-mggroup

[12] Microsoft. New-MgGroupMemberByRef cmdlet.
https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.groups/new-mggroupmemberbyref

[13] Microsoft. List managedDevices with Graph.
https://learn.microsoft.com/en-us/graph/api/intune-devices-manageddevice-list?view=graph-rest-1.0

PRIMARY MICROSOFT DOCUMENTATION

References / roles and automation

Documentation reviewed 22 October 2026. Figures, names and measured outcomes are hypothetical.

[14] Microsoft. Entra Conditional Access device filter ownership values.
https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-condition-filters-for-devices

[15] Microsoft. Update a Conditional Access policy with Graph.
https://learn.microsoft.com/en-us/graph/api/conditionalaccesspolicy-update?view=graph-rest-1.0

[16] Microsoft. Intune built-in roles and detailed permission matrix.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/ref-built-in-roles

[17] Microsoft. Custom Intune role permission actions.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/create-custom-role

[18] Microsoft. Assign a role to an Intune administrator.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/assign-role

[19] Microsoft. Get-MgGroupMember PowerShell reference.
https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.groups/get-mggroupmember

[20] Microsoft. Graph compliance policy assignment list.
https://learn.microsoft.com/en-us/graph/api/intune-deviceconfig-devicecompliancepolicyassignment-list?view=graph-rest-1.0

[21] Microsoft. Graph Intune role definition list.
https://learn.microsoft.com/en-us/graph/api/intune-rbac-roledefinition-list?view=graph-rest-1.0

[22] Microsoft. Graph Intune role assignment list.
https://learn.microsoft.com/en-us/graph/api/intune-rbac-deviceandappmanagementroleassignment-list?view=graph-rest-1.0

[23] Microsoft. Get-BitLockerVolume PowerShell reference.
https://learn.microsoft.com/en-us/powershell/module/bitlocker/get-bitlockervolume

[24] Microsoft. Confirm-SecureBootUEFI PowerShell reference.
https://learn.microsoft.com/en-us/powershell/module/secureboot/confirm-securebootuefi

[25] Microsoft. Troubleshoot device state with dsregcmd.
https://learn.microsoft.com/en-us/entra/identity/devices/troubleshoot-device-dsregcmd

[26] Microsoft. Multi Admin Approval with Microsoft Graph API.
https://learn.microsoft.com/en-us/intune/fundamentals/role-based-access-control/multi-admin-approval-graph-api